

Data Protection Impact Assessment (DPIA)

dashAI — Saksi Mata Digital yang Netral & Tertandatangani · UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi (PDP)

dashAI
2026-06-21

Table of Contents

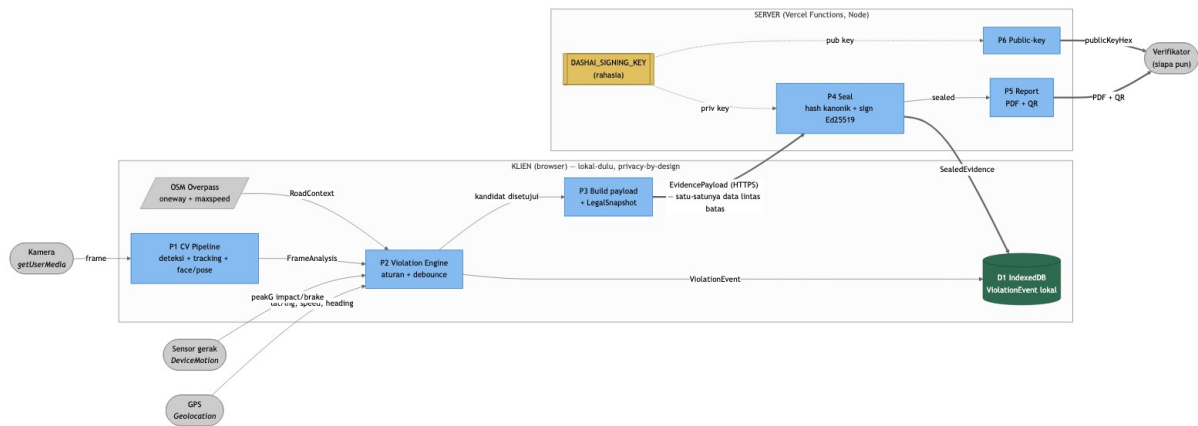
1 Pendahuluan dan Ruang Lingkup Penilaian

Dokumen ini adalah **Data Protection Impact Assessment (DPIA)** — atau **Penilaian Dampak Pelindungan Data Pribadi** — untuk **dashAI**, sebuah aplikasi web AI *dashcam* yang mendeteksi pelanggaran lalu lintas secara *real-time* langsung di dalam peramban (browser), memetakan setiap pelanggaran ke pasal **Undang-Undang Nomor 22 Tahun 2009 tentang Lalu Lintas dan Angkutan Jalan (UU LLAJ)** dari basis pengetahuan terverifikasi, lalu menyegel bukti secara kriptografis dengan tanda tangan **Ed25519** di sisi server. Aplikasi dibangun di atas Next.js 16 (App Router), React 19, TypeScript (mode strict), dan Tailwind CSS v4, serta di-deploy di Vercel pada <https://dashai-mu.vercel.app> (sumber: <https://github.com/Finerium/dashAI>, lisensi Apache-2.0).

DPIA ini disusun untuk memenuhi semangat dan kewajiban **UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP)**, khususnya kewajiban Pengendali Data Pribadi untuk melakukan penilaian dampak ketika pemrosesan berpotensi menimbulkan risiko tinggi terhadap Subjek Data Pribadi — antara lain karena melibatkan pemrosesan **data biometrik wajah**, **pemantauan/observasi sistematis di ruang publik**, **pemrosesan data lokasi (geolokasi)**, dan penggunaan **teknologi baru** (visi komputer di perangkat). DPIA ini wajib dibaca bersama dokumen `09-threat-model.md` (analisis keamanan) dan `04-software-architecture.md` (arsitektur).

Setiap pernyataan dalam dokumen ini di-ground pada kode sumber nyata di repositori — `lib/crypto/` (canonical, keys, sign, verify), `lib/cv/` (pipeline, detector, tracker, face, pose, plate), `lib/violations/engine.ts`, `lib/evidence/` (types, payload, store), `lib/geo/osm.ts`, `lib/sensors/motion.ts`, `lib/legal/citations.ts`, dan `app/api/{seal,verify,public-key,report}`. Sitasi hukum lalu lintas dijaga **persis konsisten** dengan `lib/legal/citations.ts`.

Batasan demo (kejujuran rekayasa). dashAI saat ini adalah **demo melalui kamera ponsel**, bukan dokumen resmi kepolisian. Bukti yang dihasilkan bersifat **tamper-evident**, bukan **tamper-proof**: tanda tangan Ed25519 membuktikan isi laporan tidak berubah satu byte pun sejak disegel server pada waktu tertera, tetapi **tidak** membuktikan bahwa kamera benar-benar menyaksikan peristiwa di dunia nyata. Kejujuran ini relevan untuk DPIA karena membatasi klaim apa yang boleh disandarkan pada bukti, sekaligus membatasi insentif untuk memperluas pemrosesan data pribadi.



Data Flow Diagram dashAI — aliran data lintas batas kepercayaan klien/server. Satu-satunya data yang melintasi batas ke server adalah *EvidencePayload* yang disegel pengguna secara eksplisit.

1.1 Identifikasi Para Pihak

Peran (UU PDP)	Pihak	Catatan
Pengendali Data Pribadi	Pemilik perangkat / pengguna dashAI	Pengguna menentukan tujuan dan cara pemrosesan saat mengoperasikan dashcam; bukti tersimpan lokal di perangkatnya (IndexedDB).
Pengendali Data Pribadi (penyedia platform)	Tim dashAI	Menyediakan kode aplikasi, <i>endpoint</i> /api/seal, /api/verify, /api/report, /api/public-key, dan kunci penandatanganan DASHAI_SIGNING_KEY. Lihat batasan pemrosesan di Bab 3.
Prosesor Data Pribadi	Vercel	<i>Hosting</i> aplikasi & menjalankan <i>serverless functions</i> (runtime Node.js) yang menerima payload tersegel.
Pihak Ketiga (penyedia layanan publik)	OpenStreetMap Overpass; CDN model (jsdelivr, Google Storage, TF Hub)	Lihat Bab 7 untuk pertimbangan lintas batas/pihak ketiga.
Subjek Data Pribadi	(1) Pemilik/pengemudi (subjek self); (2) Pengguna jalan lain yang terekam (subjek other)	Tipe Subject di <code>lib/evidence/types.ts</code> membedakan keduanya secara eksplisit.

Catatan: Karena arsitektur dashAI bersifat **local-first**, untuk sebagian besar daur hidup bukti **tidak ada server yang memegang data pribadi**. Server hanya berperan ketika pengguna **secara eksplisit** menyegel sebuah peristiwa.

2 Tujuan dan Dasar Hukum Pemrosesan

2.1 Tujuan Pemrosesan

dashAI memiliki tujuan ganda (*dual-subject*) yang spesifik dan eksplisit:

1. **Penegakan terhadap pihak lain (laporan tilang).** Mendeteksi pelanggaran lalu lintas yang dilakukan pengguna jalan lain (*subject*: "other") dan menyusun bukti tersegel beserta sitasi pasal UU LLAJ untuk pelaporan.
2. **Perlindungan pemilik (bukti yang meringankan / *exculpatory*).** Mengumpulkan bukti objektif untuk melindungi pemilik dari fitnah, tilang yang keliru, atau eskalasi konflik di jalan (*subject*: "self") — termasuk pemicu otomatis berbasis sensor benturan/pengereman keras (*lib/sensors/motion.ts*) agar rekaman sekitar tersegel meski pengemudi tak dapat menyentuh ponsel.
3. **Pembinaan mandiri (*self-coaching*).** Membantu pemilik mengenali dan tidak mengulang kesalahannya sendiri (laporan jenis *coaching*).

Tujuan-tujuan ini bersifat **terbatas, sah, dan dinyatakan secara jelas** — sejalan dengan prinsip *purpose limitation* UU PDP. dashAI **tidak** memproses data pribadi untuk pemasaran, pemprofilan komersial, pelatihan model identitas, atau tujuan lain di luar yang disebutkan.

2.2 Dasar Hukum (Lawful Basis) menurut UU PDP

UU PDP (Pasal 20) mensyaratkan dasar pemrosesan yang sah. dashAI menyandarkan pemrosesannya pada kombinasi dasar berikut, sesuai konteks subjek data:

Dasar pemrosesan (Pasal 20 UU PDP)	Penerapan di dashAI
Persetujuan (consent) yang sah dari Subjek Data	Berlaku untuk subjek <i>self</i> (pemilik): pengguna secara aktif memberi izin kamera (<i>getUserMedia</i>), lokasi (<i>Geolocation</i>), dan sensor gerak (iOS 13+ meminta izin eksplisit via <i>requestMotionPermission</i> , lihat <i>lib/sensors/motion.ts</i>).
Pelaksanaan kepentingan yang sah (legitimate interest) dengan memperhatikan keseimbangan hak Subjek Data	Berlaku untuk subjek <i>other</i> : kepentingan sah pengguna untuk melindungi diri dari fitnah dan untuk melaporkan pelanggaran yang ia saksikan di ruang publik, diimbangi dengan mitigasi privasi (deteksi-bukan-pengenalan, blur, minimisasi).
Pemenuhan kewajiban hukum / pelaksanaan kewenangan (saat bukti diserahkan ke pihak berwenang)	Penilaian akhir atas bukti tetap berada pada pihak berwenang; dashAI menyediakan bukti tersegel yang dapat diverifikasi, bukan keputusan hukum.

Keterbatasan jujur. Untuk subjek *other* di ruang publik, persetujuan individual tidak praktis dikumpulkan. Karena itu dashAI **mengurangi intrusi** seminimal mungkin (Bab 3) dan tidak melakukan identifikasi biometrik. Keputusan apakah suatu bukti dapat digunakan secara hukum tetap menjadi kewenangan penegak hukum, bukan klaim sistem.

2.3 Keselarasan dengan Prinsip UU PDP

Prinsip (UU PDP Pasal 16)	Bagaimana dashAI memenuhinya
Terbatas & spesifik, sah, transparan	Tujuan dinyatakan jelas (di atas); kode bersifat <i>open-source</i> (Apache-2.0) sehingga pemrosesan dapat diaudit publik.
Sesuai tujuan	Payload yang disegel (<i>EvidencePayload</i>) hanya memuat <i>field</i> yang relevan untuk pembuktian pelanggaran; lihat Bab 2.x.
Akurat & mutakhir	Stempel waktu disegel server (<i>sealedAt</i> , otoritatif); kecepatan diri dari GPS akurat; kecepatan kendaraan lain ditandai sebagai estimasi .
Melindungi keamanan	Hash kanonik SHA-256 + tanda tangan Ed25519; satu-satunya rahasia <code>DASHAI_SIGNING_KEY</code> tak pernah keluar server.
Memberitahukan tujuan & akuntabilitas	DPIA ini, README, dan halaman <code>/verify</code> mandiri.
Dapat dihapus/dimusnahkan	Penyimpanan lokal <code>IndexedDB</code> sepenuhnya dapat dihapus pengguna (Bab 8).

3 Deskripsi Pemrosesan Data

Bagian ini mendeskripsikan secara teknis kategori data pribadi yang diproses dashAI, sumbernya, tempat pemrosesan (klien vs server), dan retensinya. Acuan: `lib/cv/`, `lib/geo/`, `lib/sensors/`, `lib/evidence/types.ts`.

3.1 Inventaris Data Pribadi yang Diproses

Kategori data	Sumber	Tempat pemrosesan	Masuk ke payload tersegel?	Kategori UU PDP
Citra wajah (lokasi/bounding box)	Kamera MediaPipe BlazeFace (<code>lib/cv/face.ts</code>)	→ Klien saja	Tidak (hanya hash media opsional)	Data biometrik (spesifik, Pasal 4 ayat (2)) — namun lihat catatan minimisasi
Pelat nomor kendaraan	Kamera Tesseract.js (<code>lib/cv/plate.ts</code>)	→ Klien saja (OCR di perangkat)	Ya, sebagai <code>plateText</code> (jika diisi)	Data pribadi yang dapat mengidentifikasi kendaraan/pemilik secara tidak langsung
Lokasi geografis (GPS)	Geolocation API (<code>lib/geo/location.ts</code>)	Klien; dibulatkan saat dikirim ke OSM	Ya, sebagai <code>location: GeoPoint</code> jika pengguna	Data lokasi (sensitif konteks)

Kategori data	Sumber	Tempat pemrosesan	Masuk ke payload tersegel?	Kategori UU PDP
Kecepatan & arah (heading)	GPS (akurat, self); estimasi CV (other)	Klien	Ya: <code>egoSpeedKmh</code> , <code>otherSpeedKmh</code> , <code>speedLimitKmh</code>	Data perilaku berkendara
Citra kendaraan & adegan (frame)	Kamera → <code>coco-ssd (lib/cv/detector.ts)</code>	Klien	Tidak (hanya <code>mediaHashes SHA-256 opsional</code>)	Citra ruang publik
Sensor gerak (g-force)	<code>DeviceMotion (lib/sensors/motion.ts)</code>	Klien	Tidak langsung; memicu penyegelan	Telemetri perangkat
Identitas perangkat	<code>navigator.userAgent, platform</code>	Klien → server (opsional)	Ya, <code>device.userAgent</code> , <code>device.platform</code> (opsional)	Data teknis

Prinsip kunci: Citra wajah dan *frame* mentah **tidak pernah** dikirim ke server. Server hanya menerima `EvidencePayload` — sebuah objek JSON terstruktur — dan, untuk media, hanya **hash SHA-256** opsional (`MediaHashes`) yang meng-*commit* ke gambar tanpa memuat *byte*-nya (`lib/evidence/types.ts`). Ini ditegaskan dalam komentar tipe: media direferensikan dengan hash “so the signed payload commits to the imagery without bloating the signature with megabytes of base64.”

3.2 Pemrosesan Wajah (Face): Deteksi, Bukan Pengenalan

dashAI menggunakan **MediaPipe BlazeFace short-range** (`lib/cv/face.ts`). Yang dilakukan adalah **face DETECTION** — menemukan posisi wajah (bounding box) untuk keperluan *crop* dan *blur*. Komentar kode menyatakannya secara tegas:

“dashAI does face DETECTION only (locating faces to crop + blur) — never recognition. This is the privacy-by-design boundary: we never match a face to an identity.”

Konsekuensi penting untuk UU PDP:

- **Tidak ada *face embedding*/template biometrik** yang dihitung, disimpan, atau dicocokkan ke identitas.
- *Face crop* (`faceCrop` pada `ViolationEvent`) **selalu di-blur di antarmuka** dan **tidak masuk** ke `EvidencePayload`.
- Karena tidak ada pengenalan identitas, intensitas pemrosesan data biometrik ditekan ke titik serendah mungkin sambil tetap memenuhi tujuan (mengaburkan wajah demi privasi).

3.3 Pemrosesan Pelat Nomor (Plate OCR)

OCR pelat (`lib/cv/plate.ts`, Tesseract.js) hanya dijalankan pada **region kecil yang sudah di-crop** dari *frame* pelanggaran terkonfirmasi — **tidak** pada *live stream* penuh (OCR mahal). Hasil dinormalisasi terhadap pola pelat Indonesia (PLATE_RE). Pelat (`plateText`) **boleh** masuk ke payload tersegel karena merupakan elemen pembuktian yang diperlukan untuk pelaporan; di antarmuka, *plate crop* di-blur secara *default* sebagaimana wajah.

3.4 Pemrosesan Lokasi dan Konteks Jalan

- Lokasi diambil dari Geolocation API (`lib/geo/location.ts`) dengan `enableHighAccuracy: true`.
- Untuk konteks jalan (*oneway*, *maxspeed*), dashAI mengkueri **OpenStreetMap Overpass** (`lib/geo/osm.ts`). Sebelum dikirim ke server pihak ketiga, koordinat **dibulatkan ke 4 desimal (~11 meter)**. Komentar kode: “so we never send full-precision coordinates to the third-party Overpass servers.” Lihat Bab 7.
- Lokasi penuh hanya masuk ke payload tersegel jika pengguna menyegel suatu peristiwa, dan tetap berada di perangkat hingga pengguna memutuskan membuat laporan.

3.5 Pemrosesan Kecepatan (Akurat vs Estimasi)

dashAI bersikap jujur soal akurasi — relevan untuk prinsip **akurasi data** UU PDP:

- **Kecepatan diri (self):** GPS dibandingkan dengan *maxspeed* OSM — **akurat** (`ruleSpeedingSelf` di `engine.ts`, ambang margin `SPEED_MARGIN_KMH = 5`).
- **Kecepatan kendaraan lain (other): estimasi** dari perubahan skala bounding-box + *optical flow*, dan dalam katalog (`lib/legal/catalog.ts`) dinyatakan eksplisit “dengan rentang error”. Payload memisahkan `egoSpeedKmh` (akurat) dari `otherSpeedKmh` (estimasi) agar tidak ada klaim berlebihan.

3.6 Apa yang Disegel Server: Batas Kriptografis

Batas kriptografis adalah `EvidencePayload` (lihat `lib/evidence/types.ts`). Inilah **satu-satunya** data yang melintasi batas klien→server, dan hanya **atas tindakan eksplisit** pengguna (penyegelan). *Field*-nya:

Field payload	Jenis	Sifat privasi
<code>schema, eventId</code>	metadata	non-pribadi
<code>violation, subject</code>	klasifikasi	non-pribadi
<code>capturedAt, sealedAt</code>	waktu (server otoritatif)	non-pribadi
<code>confidence</code>	skor 0..1	non-pribadi
<code>vehicleClass</code>	kelas COCO	non-pribadi
<code>plateText</code>	pelat (opsional)	pribadi (tidak langsung)
<code>egoSpeedKmh/</code> <code>otherSpeedKmh/</code> <code>speedLimitKmh</code>	kecepatan	perilaku
<code>location</code> (GeoPoint), <code>road</code> (RoadContext)	lokasi	pribadi/sensitif

Field payload	Jenis	Sifat privasi
mediaHashes	SHA-256 (bukan gambar)	non-pribadi (hash)
legal (LegalSnapshot)	sitasi pasal	non-pribadi
device (opsional)	userAgent/platform	teknis

Komentar kode menegaskan bobot evidensial hanya pada payload: “Anything outside the payload is presentation only and carries no evidentiary weight.”

4 Minimisasi Data dan Privacy-by-Design

dashAI menerapkan **privacy-by-design** dan **privacy-by-default** — prinsip yang ditegaskan UU PDP — bukan sebagai *add-on*, melainkan sebagai keputusan arsitektural inti.

4.1 Tiga Pilar Privacy-by-Design

1. **Deteksi-bukan-pengenalan (*detection, not recognition*)**. Wajah hanya dilokalisasi untuk di-blur; tidak ada template biometrik, tidak ada pencocokan identitas (`lib/cv/face.ts`).
2. **Blur secara default (*blur-by-default*)**. Di antarmuka, *face crop* dan *plate crop* di-blur secara default (lihat `ViolationEvent.faceCrop` — “always blurred in the UI”, `lib/evidence/types.ts`).
3. **Local-first**. Bukti disimpan terlebih dahulu di **IndexedDB** lokal (`lib/evidence/store.ts`, database dashai). Komentar: “dashAI keeps the owner’s evidence on their own device by default... The server only ever sees a payload when the user explicitly seals/reports an event.”

4.2 Penerapan Minimisasi Data secara Konkret

Teknik minimisasi	Lokasi di kode	Efek privasi
Frame mentah tak pernah di-upload	<code>app/api/seal/route.ts</code> menerima event + mediaHashes, bukan gambar	Server tidak pernah memegang citra mentah
Media direferensikan via hash SHA-256	MediaHashes di <code>types.ts</code> ; <code>lib/crypto/canonical.ts</code>	Payload meng-commit ke gambar tanpa memuatnya
Koordinat dibulatkan ~11 m sebelum ke pihak ketiga	<code>lib/geo/osm.ts</code> (<code>toFixed(4)</code>)	Lokasi presisi penuh tak bocor ke Overpass
OCR hanya pada crop pelanggaran terkonfirmasi	<code>lib/cv/plate.ts</code>	Tidak ada OCR massal pada <i>live stream</i>
Debounce & gating umur track	<code>engine.ts</code> (<code>DEBOUNCE_MS=6000</code> , <code>MIN_TRACK_AGE=4</code>)	Mengurangi <i>capture</i> berlebihan / <i>false positive</i>
Penyegelan bersifat opt-in eksplisit	Alur klien → <code>/api/seal</code>	Tidak ada pengiriman otomatis
Cache OSM per sel grid ~11 m	<code>lib/geo/osm.ts</code>	Mengurangi frekuensi kueri

Teknik minimisasi	Lokasi di kode	Efek privasi
	(cacheKey)	lokasi keluar
Tanpa API key pihak ketiga	README (.env.example)	Tidak ada <i>tracker</i> /akun pihak ketiga yang terikat identitas

4.3 Default yang Menguntungkan Privasi

- **Tanpa akun, tanpa basis data identitas.** dashAI tidak memiliki sistem login; tidak ada profil pengguna persisten di server.
- **Tanpa telemetri/analitik pihak ketiga** yang terikat identitas. README menegaskan “Tidak ada API key pihak ketiga yang dibutuhkan.”
- **Open-source (Apache-2.0).** Klaim privacy-by-design dapat diverifikasi siapa pun terhadap kode.

5 Keabsahan Pemrosesan dan Hak Subjek Data

5.1 Keabsahan Pemrosesan

Pemrosesan disandarkan pada dasar hukum di Bab 2 (persetujuan untuk *self*; kepentingan sah yang seimbang untuk *other*; pemenuhan kewajiban/kewenangan saat bukti diserahkan ke pihak berwenang). Karena arsitektur *local-first*, untuk sebagian besar siklus hidup data, pemrosesan terjadi **sepenuhnya di perangkat Subjek Data Pribadi yang juga Pengendali** (pemilik), sehingga risiko pihak ketiga berkurang signifikan.

5.2 Hak Subjek Data Pribadi (UU PDP Pasal 5–13) dan Cara Pemenuhannya

Hak Subjek Data (UU PDP)	Pemenuhan di dashAI
Hak atas informasi (Pasal 5)	DPIA ini, README, halaman <code>/verify</code> mandiri, dan kode sumber terbuka menjelaskan tujuan & jenis pemrosesan.
Hak akses & memperoleh salinan (Pasal 6, 7)	Pemilik memiliki seluruh bukti di IndexedDB lokal; dapat membaca semua <code>ViolationEvent</code> (<code>getAllEvents</code> di <code>store.ts</code>) dan mengekspor PDF tertandatangani via <code>/api/report</code> .
Hak memperbaiki/memperbarui (Pasal 8)	Sebelum penyegelan, pengguna meninjau & dapat membatalkan suatu peristiwa. Setelah disegel, isi tidak dapat diubah diam-diam: perubahan akan terdeteksi (hash tidak cocok) — properti <i>tamper-evident</i> yang justru melindungi integritas.
Hak mengakhiri/menarik persetujuan & keberatan (Pasal 9)	Pengguna dapat menghentikan kamera/lokasi/sensor kapan saja (mencabut izin peramban); tidak ada pemrosesan berlanjut di latar.
Hak menghapus/memusnahkan (Pasal 8, 13)	<code>deleteEvent(id)</code> dan <code>clearEvents()</code>

Hak Subjek Data (UU PDP)	Pemenuhan di dashAI
	di <code>store.ts</code> menghapus bukti lokal; menghapus data situs peramban memusnahkan IndexedDB sepenuhnya. Lihat Bab 8.
Hak atas keputusan otomatis (Pasal 10)	dashAI tidak mengambil keputusan hukum otomatis; ia menghasilkan bukti + sitasi indikatif. Penilaian akhir ada pada manusia/pihak berwenang. <i>confidence</i> bersifat informatif, bukan vonis.
Hak menunda/membatasi pemrosesan (Pasal 11)	Pemrosesan bersifat <i>opt-in</i> per sesi; tidak ada agregasi server yang berjalan terus.
Hak menuntut ganti rugi & mengadukan (Pasal 12)	Kanal pelaporan kerentanan tersedia (<code>SECURITY.md</code>); identitas Pengendali platform diketahui (repositori publik).
Catatan untuk subjek other. Karena dashAI tidak mengenali identitas dan tidak menyimpan data pihak lain di server (kecuali payload yang disegel pemilik untuk pelaporan sah), pelaksanaan hak akses/penghapusan untuk pihak lain praktis terjadi melalui Pengendali (pemilik perangkat) dan/atau pihak berwenang yang menerima laporan. Minimisasi (tanpa pengenalan biometrik, blur default) mengurangi materi data pribadi pihak lain yang perlu dikelola.	

6 Penilaian Risiko terhadap Subjek Data

Bagian ini menilai risiko terhadap **Subjek Data Pribadi** (bukan risiko keamanan sistem secara umum — itu di `09-threat-model.md`). Skala kemungkinan/dampak: Rendah / Sedang / Tinggi. Skor residual mempertimbangkan mitigasi pada Bab 6.

ID	Risiko terhadap Subjek Data	Kemungkinan (sebelum mitigasi)	Dampak	Mitigasi utama	Risiko residual
P1	Identifikasi biometrik wajah orang di ruang publik tanpa dasar	Sedang	Tinggi	Deteksi-bukan-pengenalan; tidak ada <i>embedding</i> ; blur default; wajah tak masuk payload	Rendah
P2	Kebocoran lokasi presisi ke pihak ketiga (Overpass)	Sedang	Sedang	Koordinat dibulatkan ~11 m; cache lokal; <i>graceful degrade</i>	Rendah
P3	Penyalahgunaan pelat	Sedang	Sedang	OCR hanya pada	Rendah-Sedang

ID	Risiko terhadap Subjek Data	Kemungkinan (sebelum mitigasi)	Dampak	Mitigasi utama	Risiko residual
	nomor untuk melacak individu			pelanggaran terkonfirmasi; tidak ada basis data pelat persisten di server	
P4	Tuduhan keliru akibat estimasi kecepatan kendaraan lain	Sedang	Tinggi	otherSpeedKmh ditandai estimasi; dipisah dari egoSpeedKmh; disclaimer; tamper-evident bukan tamper-proof	Sedang
P5	Surveilans berlebihan / function creep (perluasan tujuan diam-diam)	Rendah	Tinggi	Tujuan terbatas; <i>open-source</i> auditable; payload minimal; tanpa akun	Rendah
P6	Pemalsuan bukti yang merugikan pihak lain (arahkan kamera ke layar)	Sedang	Tinggi	Disclaimer tamper-evident; <i>roadmap</i> device attestation; penilaian akhir pihak berwenang	Sedang
P7	Kebocoran/ penyalahgunaan kunci DASHAI_SIGNING_KEY	Rendah	Tinggi	Satu rahasia, tak pernah keluar server; server-only; rotasi kunci (keyId ber-prefix)	Rendah
P8	Persistensi bukti tak terbatas di perangkat (kehilangan/pencurian)	Sedang	Sedang	Penyimpanan lokal terenkripsi peramban; hak hapus deleteEve	Sedang

ID	Risiko terhadap Subjek Data	Kemungkinan (sebelum mitigasi)	Dampak	Mitigasi utama	Risiko residual
P9	Akses pihak ketiga ke data via prosesor (Vercel)	Rendah	Sedang	nt/clearEvents Hanya payload tersegel yang sampai server; tanpa media mentah; tanpa identitas	Rendah
P10	Pengoperasian ponsel saat mengemudi (risiko keselamatan, bukan data)	Sedang	Tinggi	Disclaimer eksplisit di README; pemicu sensor otomatis mengurangi interaksi manual	Sedang

Risiko keselamatan (P10) berada di luar lingkup murni UU PDP tetapi dicatat karena menyangkut keselamatan Subjek Data; mitigasinya adalah peringatan eksplisit dan *roadmap* perangkat keras khusus (mengurangi kebutuhan menyentuh ponsel).

7 Mitigasi dan Pengamanan

7.1 Pengamanan Teknis (Technical Safeguards)

Pengamanan	Implementasi	Risiko yang ditangani
Integritas kriptografis	Hash kanonik SHA-256 (<code>lib/crypto/canonical.ts</code>) + tanda tangan Ed25519 (<code>lib/crypto/sign.ts</code>)	P4, P6 (deteksi perubahan isi)
Verifikasi publik tanpa percaya UI	Public key di <code>/api/public-key</code> ; verifikasi sisi klien (<code>lib/crypto/verify.ts</code>)	P5, P6
Isolasi kunci rahasia	DASHAI_SIGNING_KEY dibaca <code>server-only</code> (<code>import "server-only" di sign.ts</code>), tak pernah dikirim ke klien (<code>lib/crypto/keys.ts</code>)	P7
Penandaan kunci DEV vs	<code>keyId</code> ber-prefix	P6, P7

Pengamanan	Implementasi	Risiko yang ditangani
PROD	dev-/prod-; bukti DEV tak boleh dianggap otoritatif	
Minimisasi di tepi jaringan	Koordinat <code>toFixed(4)</code> sebelum Overpass; hanya hash media ke server	P2, P9
Penyimpanan lokal-dulu	IndexedDB (<code>lib/evidence/store.ts</code>); server hanya melihat payload eksplisit	P5, P9
Blur default	<i>face crop</i> & <i>plate crop</i> di-blur di UI	P1, P3
Validasi input server	<code>/api/seal</code> & <code>/api/report</code> memvalidasi <code>violation</code> ∈ CITATIONS, <code>subject</code> , tipe <code>capturedAt</code> , <code>clamp</code> confidence ke <code>[0,1]</code>	Integritas data
Verifikasi sebelum laporan resmi	<code>/api/report</code> menolak (422) envelope yang tidak valid sebelum membuat PDF	P4, P6
Degradasi anggun	Pipeline CV & OSM gagal tanpa memblok (model opsional, upload OSM null saat gagal)	Ketersediaan tanpa memaksa

7.2 Pengamanan Organisasi & Tata Kelola (Organisational Safeguards)

- **Tujuan terbatas terdokumentasi** (Bab 2) untuk mencegah *function creep* (P5).
- **Transparansi via open-source** (Apache-2.0) — klaim privasi dapat diaudit publik.
- **Provenans hukum terverifikasi** — sitasi UU LLAJ digenerate dari workflow riset multi-agent dengan **verifikasi adversarial 3-voter** (12/12 sitasi `verified: true`, lihat `lib/legal/citations.ts` dan `docs/research/phase0-research.json`), mengurangi risiko tuduhan keliru berbasis dasar hukum yang salah.
- **Disclaimer kejujuran** — README menyatakan eksplisit: tamper-evident bukan tamper-proof; estimasi kecepatan kendaraan lain bersifat perkiraan; laporan bukan dokumen resmi kepolisian.
- **Kanal pelaporan kerentanan** — SECURITY.md.

7.3 Pengamanan yang Direncanakan (Roadmap)

Sesuai *roadmap* README, untuk produksi: **device attestation** (Play Integrity / App Attest), kontinuitas GPS, dan dashcam perangkat keras khusus untuk menaikkan biaya pemalsuan (menangani P6). Ini menambah jaminan integritas asal-usul rekaman, bukan hanya integritas isi.

8 Pertimbangan Lintas Batas dan Pihak Ketiga

8.1 OpenStreetMap Overpass (Konteks Jalan)

dashAI mengkueri Overpass untuk oneway dan maxspeed (`lib/geo/osm.ts`). *Endpoint*:

- <https://overpass-api.de/api/interpreter>
- <https://overpass.kumi.systems/api/interpreter>

Pertimbangan privasi & lintas batas:

Aspek	Status di dashAI
Data yang dikirim	Hanya koordinat dibulatkan ke ~11 m + kueri way di sekitar radius 25 m; tidak ada identitas, pelat, wajah, atau ID perangkat
Lokasi server	Server Overpass berada di luar yurisdiksi Indonesia (lintas batas)
API key / akun	Tidak ada — tidak ada pengikatan ke identitas pengguna
Mekanisme minimisasi	Pembulatan presisi + cache per sel grid mengurangi frekuensi & granularitas kueri
Kegagalan	<i>Graceful degrade</i> (<code>null</code>) — tidak memblok pipeline, tidak memaksa pengiriman

Catatan lintas batas (UU PDP Pasal 56). Pengiriman koordinat kasar (presisi ~11 m, tanpa pengenalan pribadi) ke server Overpass di luar negeri merupakan **transfer data minimal**. Karena data tidak mengidentifikasi individu dan tidak disertai pengenalan, paparan terhadap Subjek Data sangat ditekan. Untuk produksi, opsi *self-hosting* instans Overpass dapat menghilangkan transfer lintas batas ini sepenuhnya.

8.2 CDN Model (Pemuatan Bobot/WASM)

Model dimuat saat *runtime* dari CDN (nothing bundled):

Komponen	Sumber
TensorFlow.js (<code>lite_mobilenet_v2</code>)	coco-ssd TF Hub CDN (<code>lib/cv/detector.ts</code>)
MediaPipe Tasks Vision WASM	<code>cdn.jsdelivr.net/npm/@mediapipe/tasks-vision@0.10.35/wasm</code>
MediaPipe BlazeFace / Pose Landmarker <code>.tflite/.task</code>	<code>storage.googleapis.com/mediapipe-models/...</code>
Tesseract.js (eng)	dimuat dinamis di klien

Pemuatan model adalah unduhan **read-only**: dashAI mengunduh bobot, **tidak mengunggah** data pribadi ke CDN tersebut. Risiko utama terbatas pada metadata jaringan (alamat IP, *User-Agent*) yang inheren pada setiap permintaan HTTP, sama seperti memuat aset statis biasa.

8.3 Prosesor Hosting (Vercel)

Vercel meng-host aplikasi dan menjalankan *serverless functions* (runtime = "nodejs" pada `/api/seal`, `/api/verify`, `/api/report`, `/api/public-key`). Yang sampai ke fungsi server hanyalah **payload tersegel yang dikirim pengguna secara eksplisit** — bukan *frame*, bukan wajah, bukan *live stream*. Untuk produksi, hubungan dengan prosesor sebaiknya diformalkan melalui **perjanjian pemrosesan data (DPA)** sesuai UU PDP.

9 Retensi dan Penghapusan Data

9.1 Kebijakan Retensi

dashAI menerapkan retensi **berbasis perangkat dan dikendalikan pengguna** (sejalan prinsip *storage limitation* UU PDP):

Data	Lokasi simpan	Retensi	Kontrol penghapusan
ViolationEvent (termasuk <i>frame</i> , <i>faceCrop</i> , <i>plateCrop</i> lokal)	IndexedDB peramban (<i>store.ts</i> , <i>dashai</i>)	Sampai pengguna menghapus/membersihkan data situs	<code>deleteEvent(id)</code> , <code>clearEvents()</code> , atau hapus data situs di peramban
EvidencePayload tersegel	IndexedDB lokal (disimpan kembali setelah <code>/api/seal</code>)	Idem	Idem
Payload di sisi server	Tidak ada penyimpanan persisten server — <code>/api/seal</code> & <code>/api/report</code> bersifat <i>stateless</i> (memproses lalu mengembalikan, tanpa basis data)	Tidak diretensi	N/A (tidak tersimpan)
Laporan PDF	Dihasilkan <i>on-demand</i> ; verifikasi tertanam di dalam dokumen (QR + URL), tanpa <i>lookup</i> basis data	Sesuai keputusan pengguna yang menyimpan/membagikan PDF	Pengguna menghapus file PDF
Cache OSM	Memori klien (Map di <i>osm.ts</i>)	Selama sesi/tab	Hilang saat tab/proses ditutup

Sifat *stateless server* ditegaskan pada `app/api/report/route.ts`: verifikasi berjalan mandiri di dalam dokumen ("self-contained and needs no database lookup — tamper-evidence without state"). Tidak adanya basis data server berarti **tidak ada gudang data pribadi terpusat** yang perlu diretensi atau berisiko bocor.

9.2 Mekanisme Penghapusan

- **Penghapusan per peristiwa:** `deleteEvent(id)` (*store.ts*).

- **Penghapusan menyeluruh:** `clearEvents()` (`store.ts`).
- **Pemusnahan total:** menghapus data situs/peramban memusnahkan seluruh IndexedDB dashai.
- **Tidak ada residu server** yang perlu dihapus karena server tidak menyimpan payload.

Karena penyimpanan bersifat lokal-dulu dan server *stateless*, **hak penghapusan UU PDP (Pasal 8 & 13) dapat dipenuhi sepenuhnya oleh pengguna sendiri**, tanpa bergantung pada permintaan ke pihak ketiga.

10 Risiko Residual dan Kesimpulan

10.1 Ringkasan Risiko Residual

Setelah mitigasi pada Bab 6 diterapkan, profil risiko residual terhadap Subjek Data Pribadi adalah sebagai berikut:

Tingkat residual	Risiko
Rendah	P1 (biometrik), P2 (lokasi ke pihak ketiga), P5 (function creep), P7 (kunci), P9 (prosesor)
Rendah-Sedang	P3 (penyalahgunaan pelat)
Sedang	P4 (estimasi kecepatan → tuduhan keliru), P6 (pemalsuan asal-usul rekaman), P8 (persistensi lokal pada perangkat hilang), P10 (keselamatan operasi saat berkendara)

Risiko residual **Sedang** yang tersisa terutama bersumber pada dua sifat fundamental yang **sudah dinyatakan jujur** oleh dashAI: (a) kecepatan kendaraan lain adalah **estimasi**, bukan ukuran pasti; dan (b) sistem bersifat **tamper-evident**, **bukan tamper-proof** — tanda tangan menjamin isi tidak berubah, namun **tidak** menjamin kamera menyaksikan realitas fisik. Keduanya **tidak menambah** pemrosesan data pribadi; keduanya membatasi **klaim** yang boleh disandarkan pada data. Mitigasi lanjutan (device attestation, kalibrasi estimasi dengan *error bars*, dashcam perangkat keras) ada pada *roadmap* dan akan menurunkan P4 dan P6 lebih jauh.

10.2 Penilaian Proporsionalitas

Pemrosesan dashAI **proporsional** terhadap tujuannya: ia memproses data seminimal mungkin untuk membuktikan pelanggaran (deteksi-bukan-pengenalan, blur default, lokal-dulu, payload minimal, server *stateless* tanpa media mentah), sementara manfaatnya — perlindungan pengendara dari fitnah dan penyediaan bukti netral yang dapat diverifikasi siapa pun — bersifat nyata dan selaras dengan keselamatan jalan serta keadilan. Tidak ditemukan cara yang kurang intrusif untuk mencapai tujuan yang sama tanpa kehilangan nilai pembuktian.

10.3 Kesimpulan

Berdasarkan penilaian ini, dashAI dapat memproses data pribadi dalam lingkup yang dideskripsikan **dengan tingkat risiko residual yang dapat diterima**, dengan syarat pengamanan pada Bab 6 dipelihara dan *roadmap* mitigasi (terutama device attestation dan kalibrasi estimasi kecepatan) ditindaklanjuti sebelum penggunaan produksi berskala. Arsitektur **privacy-by-design** dan **local-first** — bukan retrofit — menempatkan dashAI pada posisi yang kuat terhadap prinsip-prinsip **UU No. 27**

Tahun 2022 (PDP): minimisasi, pembatasan tujuan, akurasi yang jujur, keamanan kriptografis, dan kemudahan pemenuhan hak Subjek Data (terutama akses dan penghapusan).

Pernyataan kejujuran final. dashAI tidak mengklaim sebagai sistem yang sempurna atau dokumen resmi kepolisian. Ia adalah **saksi mata digital yang netral dan tertandatangani** yang dirancang untuk menambah, bukan menggantikan, penilaian manusia dan kewenangan pihak berwenang. DPIA ini harus ditinjau ulang setiap kali ada perubahan material pada pemrosesan data (mis. penambahan kamera kabin/driver monitoring, *backend* model baru, atau integrasi kanal pelaporan resmi).

10.4 Lampiran A — Pemetaan Pelanggaran ke Pasal (konsisten dengan `lib/legal/citations.ts`)

Pelanggaran		Pasal UU 22/2009	Subjek	Tier deteksi
Melawan arah (lawan-arus)		Pasal 287 ayat (1)	other, self	core
Pengendara helm (tanpa-helm)	tanpa	Pasal 291 ayat (1)	other	core
Penumpang helm (penumpang-tanpa-helm)	tanpa	Pasal 291 ayat (2)	other	secondary
Menerobos merah (terobos-lampu-merah)	lampu	Pasal 287 ayat (2)	other, self	core
Melanggar marka/rambu (langgar-marka)		Pasal 287 ayat (1)	other, self	secondary
Boncengan lebih dari satu (boncengan-lebih)		Pasal 292	other	core
Melebihi kecepatan (melebihi-kecepatan)	batas	Pasal 287 ayat (5)	other, self	core
Tanpa keselamatan (tanpa-sabuk)	sabuk	Pasal 289	self	cabin
Bermain ponsel saat berkendara (main-hp)	ponsel saat	Pasal 283	self	cabin
Tanpa pelat nomor sah (tanpa-plat)	pelat nomor	Pasal 280	other	secondary
Tanpa lampu malam hari (tanpa-lampu-malam)	lampu pada	Pasal 293 ayat (1)	other, self	secondary

Pelanggaran	Pasal UU 22/2009	Subjek	Tier deteksi
Motor tanpa lampu di siang hari (motor- lampu-siang)	Pasal 293 ayat (2)	other	secondary

Deteksi *live* yang aktif: lawan arah, ngebut diri sendiri (GPS vs OSM maxspeed, akurat), boncengan, terobos lampu merah. Sisanya dikatalogkan dan ditampilkan via dataset demo; deteksi penuh (helm/pelat/kabin) membutuhkan model khusus / kamera kabin (lihat *roadmap*).